NETWORKWALKS · CYBERSECURITY & ETHICAL HACKING INTERNSHIP · WEEK 2

Penetration Testing Report

Footprinting, Reconnaissance & Network Scanning

Pentester	Muhammad Abdal Khan (Cybersecurity intern, Batch B084)
Program	Cybersecurity & Ethical Hacking Internship, Networkwalks - Week 2 (W2-PM-FINAL)
Report date	12 November 2026
Modules completed	W2-PM1 (Multiple Kali tools) · W2-PM2 (GHDB) · W2-PM4 (theHarvester) · W2-PM5 (Zenmap)
Targets	1. networkwalks.com (training target) 2. microsoft.com (public OSINT only, no direct testing) 3. Public search-engine results (GHDB, passive) 4. My own lab LAN 10.0.0.0/24
Phases covered	Phase 1: Reconnaissance & Footprinting · Phase 2: Scanning & Network Discovery
Methodology	Passive and light information gathering and host discovery only. No exploitation, brute force or denial-of-service.

1. Liability Disclaimer

I performed these activities only on systems where I had permission to test, on public information that anyone can read, or on devices and networks that I own. I did not use any of this to break the law, and nothing here should be used that way. Networkwalks and the course authors are not responsible for how anyone else uses this knowledge, and every action is the responsibility of the person taking it. In most countries unauthorised access is a crime even when nothing is damaged, and misuse can mean criminal charges, fines and loss of employment.

The Google-dorking and theHarvester modules were **passive**: I viewed publicly indexed pages and public data sources only. I did not log in to, change settings on, or otherwise interact with any third-party device or service.

2. Introduction

This report covers the Week 2 practical work of my internship. It follows the first two phases of a penetration test: collecting public information about a target (*footprinting*), then discovering live hosts on a network (*scanning*). Together they show how an attacker moves from knowing nothing to holding a map of the target before a single exploit is tried.

Four modules are covered: **PM1** uses six Kali Linux tools against networkwalks.com; **PM2** uses Google Hacking Database (GHDB) dorks to find exposed cameras and open directories; **PM4** uses theHarvester to gather emails, IPs and sub-domains; and **PM5** uses Zenmap to scan my own lab network. Each step shows the command, the result, a screenshot as evidence, and why the finding matters. Footprinting was done in Kali Linux on 11 November 2026; scanning was done on a Windows PC on 12 November 2026.

3. Tools Used

Tool	Module	Purpose
Kali Linux / Windows	All	Operating systems used for reconnaissance and scanning
`whois`	PM1	Domain registration details: registrar, dates, name servers
`whatweb`	PM1	Fingerprint web technologies: server, CMS, plugins, IP
`nslookup`	PM1	Resolve the domain name to its IP address
`curl`	PM1	Read HTTP response headers
`wafw00f`	PM1	Detect a Web Application Firewall
`dnsrecon`	PM1	Enumerate DNS records (SOA, NS, MX, TXT, SRV)
Google + GHDB (Exploit-DB)	PM2	Dorks that surface exposed cameras and open directories
theHarvester 4.11.1	PM4	Collect emails, IPs and sub-domains from public sources
Zenmap / Nmap 7.993	PM5	Ping scan of the local subnet; topology graph
Windows CMD (`ipconfig`)	PM5	Local IP address and subnet

4. Activities Performed

4.1 PM1 - Footprinting with Multiple Kali Tools

Target: `networkwalks.com` · **Run on:** Kali Linux · **Date:** 11 Nov 2026

Task 1 - whois: domain registration

Command: `whois networkwalks.com`

Item	Result
Registrar	GoDaddy.com, LLC (IANA ID 146)
Created / Updated / Expires	2019-11-06 / 2025-11-12 / 2027-11-06
Domain status	clientDeleteProhibited, clientRenewProhibited, clientTransferProhibited, clientUpdateProhibited
Name servers	NS6135.HOSTGATOR.COM, NS6136.HOSTGATOR.COM (registry view); the registrar record also lists NS29.DOMAINCONTROL.COM and NS30.DOMAINCONTROL.COM
Registrant	Hidden by privacy service: Domains By Proxy, LLC (Tempe, Arizona, US)
DNSSEC	unsigned
Abuse contact	abuse@godaddy.com

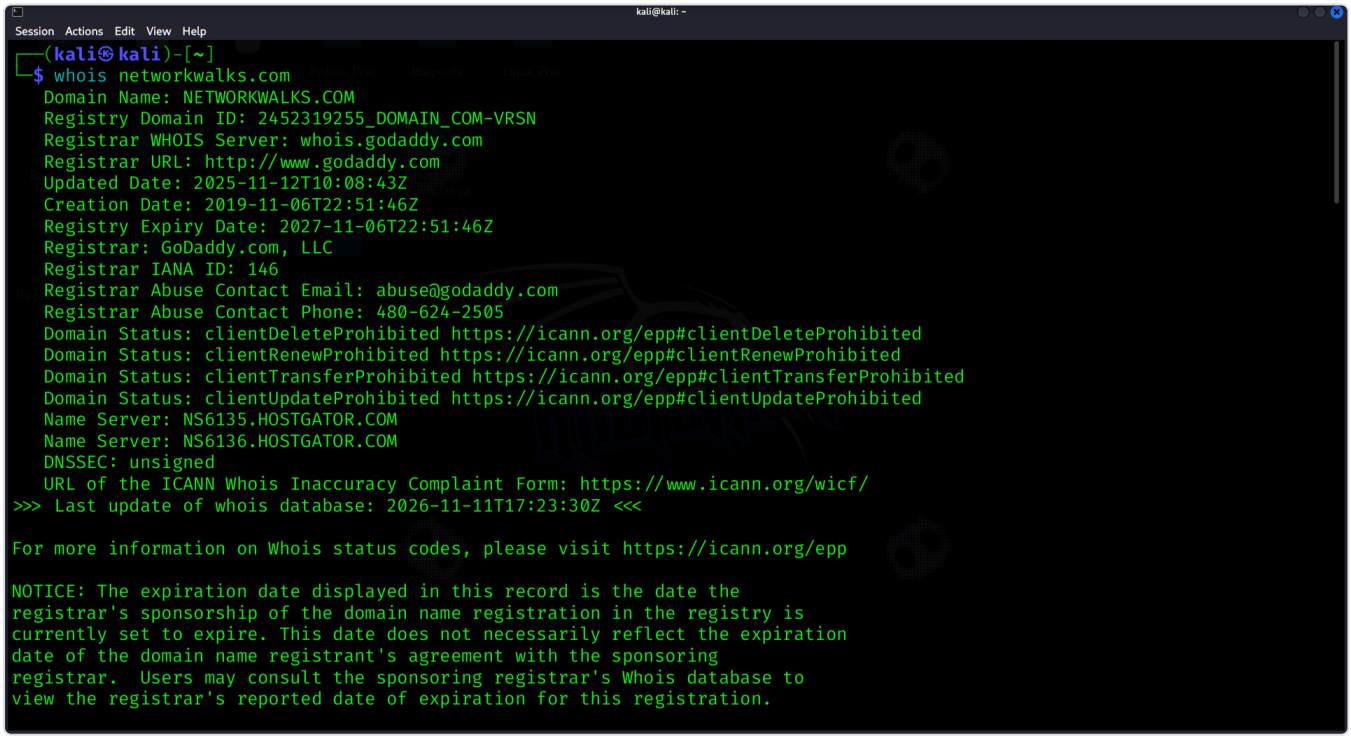


Figure 1 - whois: registry record (registrar, dates, status, name servers)

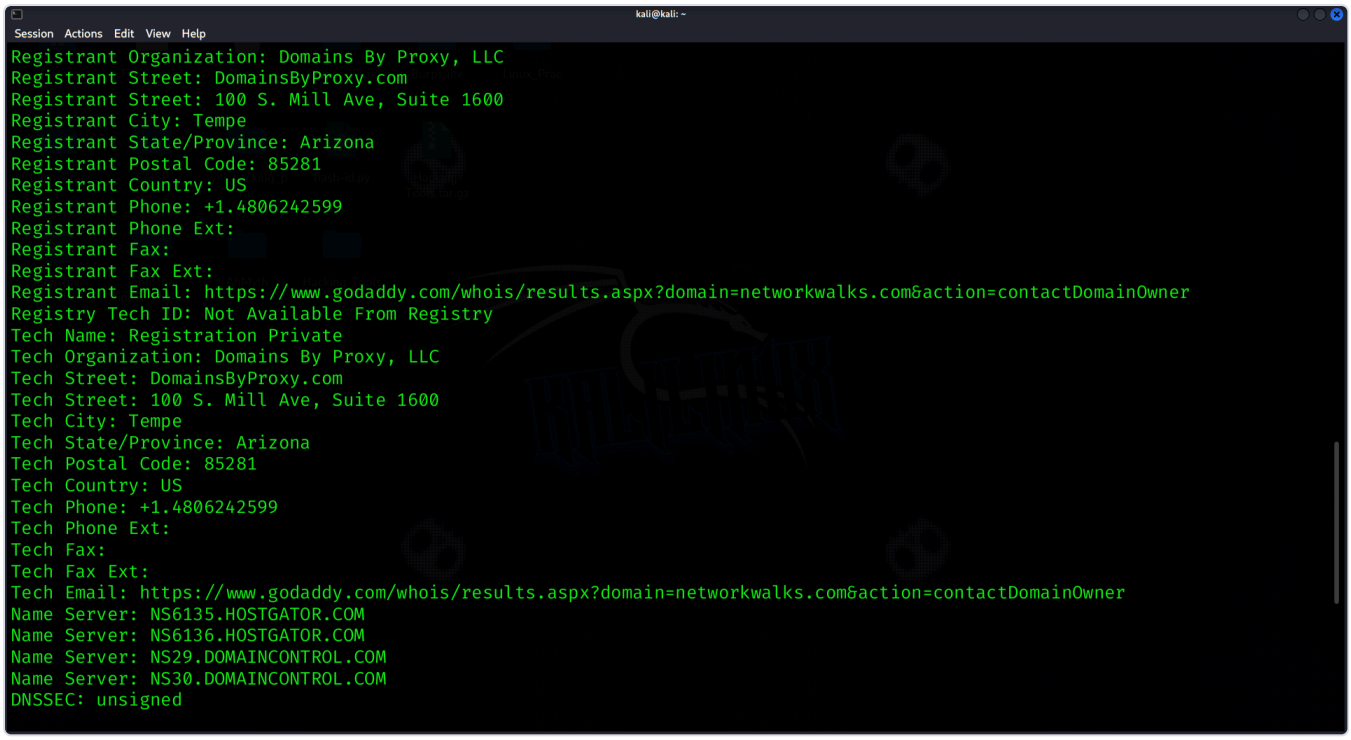


Figure 2 - whois: registrar record (privacy-protected registrant and tech contact, all four name servers)

> **Impact:** The name servers point to HostGator, so an attacker learns the hosting provider immediately. Registration dates and abuse contacts help in planning and social engineering. Registrant privacy is a good practice that is already in place; DNSSEC being unsigned is a minor gap.

Task 2 - whatweb: web technology fingerprint

Command: `whatweb networkwalks.com`

Item	Result
Redirect	`http://` returns `301 Moved Permanently` to `https://networkwalks.com/`
Web server	Apache
CMS and plugin	WordPress 7.1.4; WordPress Download Manager 3.3.76
Front-end libraries	jQuery 3.7.1; Bootstrap (tool reported "7.1.4", likely a mis-detection); HTML5; Google Tag Manager
Server IP / country	192.232.216.135 / United States
Leaked contact	info@networkwalks.com
Cookie	`__wpdm_client` (HttpOnly)
Page title	Networkwalks Academy

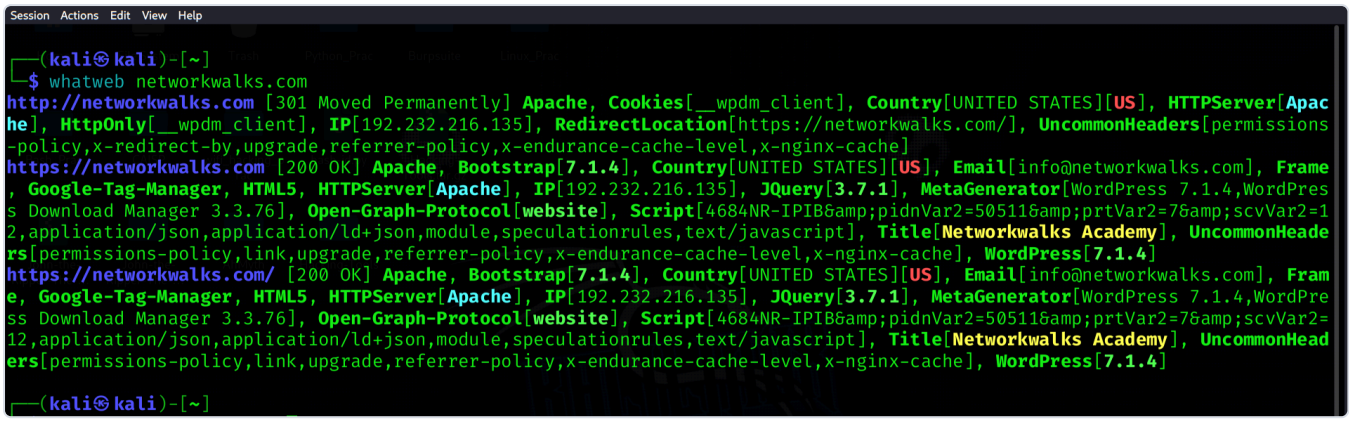


Figure 3 - whatweb fingerprint of networkwalks.com

> **Impact:** Exact software names and versions let an attacker search vulnerability databases for known issues. The tool also leaks the server IP and an email address.

Task 3 - nslookup: resolve the domain

Command: `nslookup networkwalks.com`

The lab's resolver (192.168.1.1) returned a *non-authoritative* answer: **networkwalks.com → 192.232.216.135**.

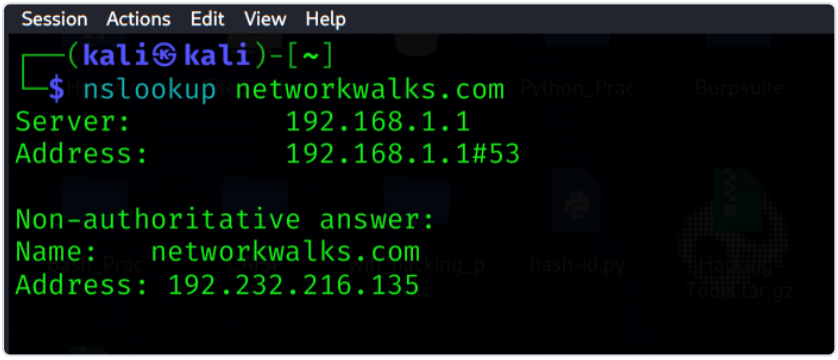


Figure 4 - nslookup result

> **Impact:** The real IP lets an attacker scan the server directly, look for other sites on the same address and map the hosting infrastructure.

Task 4 - curl: HTTP response headers

Command run: `curl -i networkwalks.com` (the task suggests `curl -I`; `-i` prints the same response headers and the 301 response has no body)

Header	Value / meaning
Status	`HTTP/1.1 301 Moved Permanently` → `Location: https://networkwalks.com/`
Server	Apache
X-Redirect-By	WordPress - Really Simple Security (reveals a security plugin)
X-nginx-cache / X-Endurance-Cache-Level	WordPress / 0 (reveals the caching stack of the hosting platform)
Set-Cookie	`__wpdm_client=…; path=/; HttpOnly` (no `Secure` flag on the HTTP response)
Referrer-Policy / Permissions-Policy	no-referrer-when-downgrade / private-state-token rules for Google, reCAPTCHA, Cloudflare, hCaptcha

Cache-Control	max-age=3600

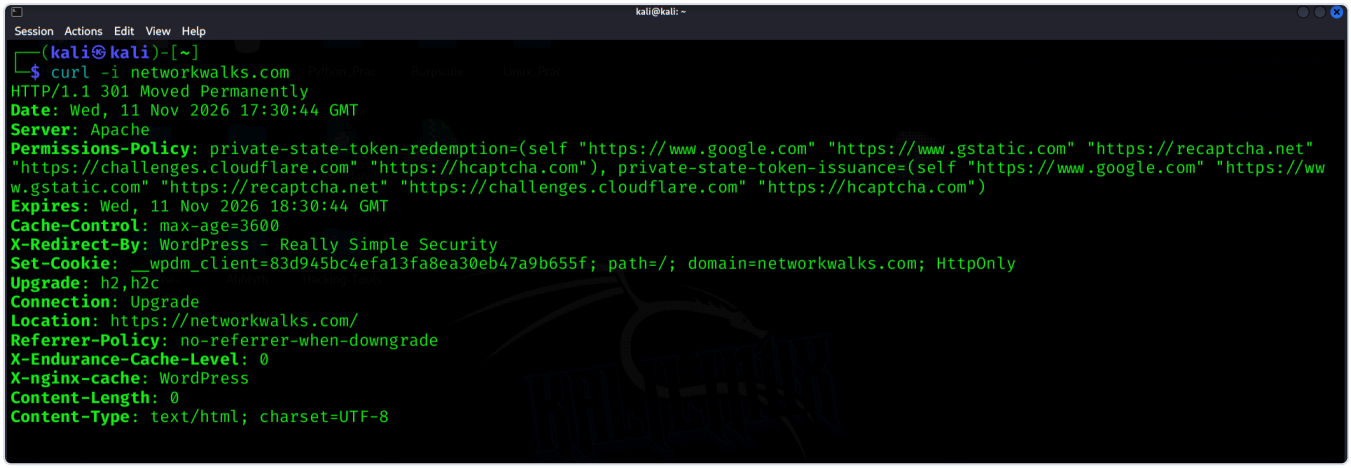


Figure 5 - curl response headers

> **Impact:** Headers fingerprint the stack (Apache, caching layers, security plugin) without loading the page. The cookie on the redirect carries no `Secure` attribute, a small hardening gap.

Task 5 - wafw00f: WAF detection

Command: `wafw00f networkwalks.com` (v2.4.2) - Result: **the site is behind ModSecurity (SpiderLabs) WAF**, detected in 2 requests.

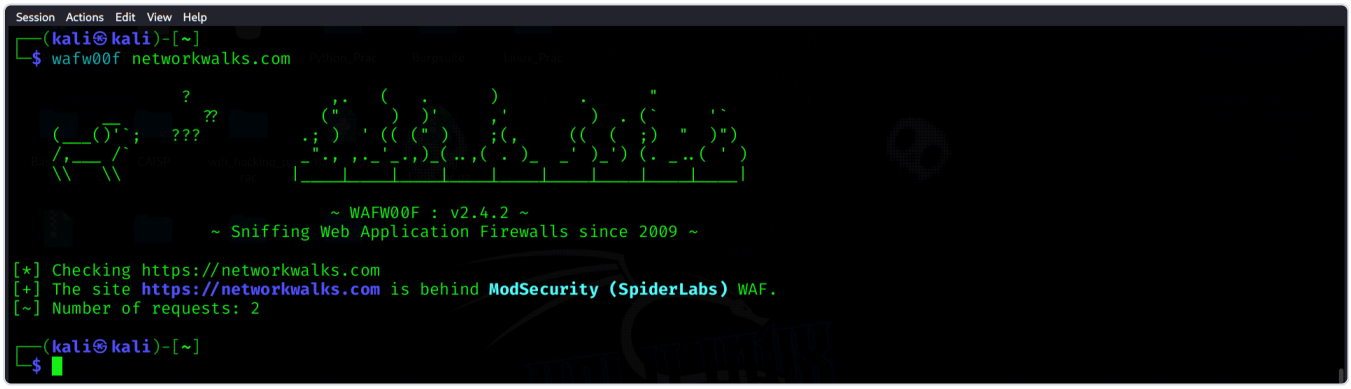


Figure 6 - wafw00f detects ModSecurity (SpiderLabs)

> **Impact:** Knowing a WAF is present shapes an attacker's plan: naive attempts would be blocked or logged, so they must adapt or try to bypass it. For defenders, the WAF is a working control.

Task 6 - dnsrecon: DNS enumeration

Command: `dnsrecon -d networkwalks.com`

Record	Result
SOA	ns6135.hostgator.com - 50.87.144.87
NS	ns6135.hostgator.com (50.87.144.87), ns6136.hostgator.com (192.232.216.131)
DNS software	BIND version banner disclosed: `9.16.23-RH`
MX / A	mail.networkwalks.com → 192.232.216.135; networkwalks.com → 192.232.216.135 (web and mail share one IP)
TXT (SPF)	`v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all` (soft-fail)

TXT	google-site-verification token present
SRV	8 × `_autodiscover._tcp` → cpanelemaildiscovery.cpanel.net :443
DNSSEC	No answer to the DNSSEC query (consistent with whois: unsigned)

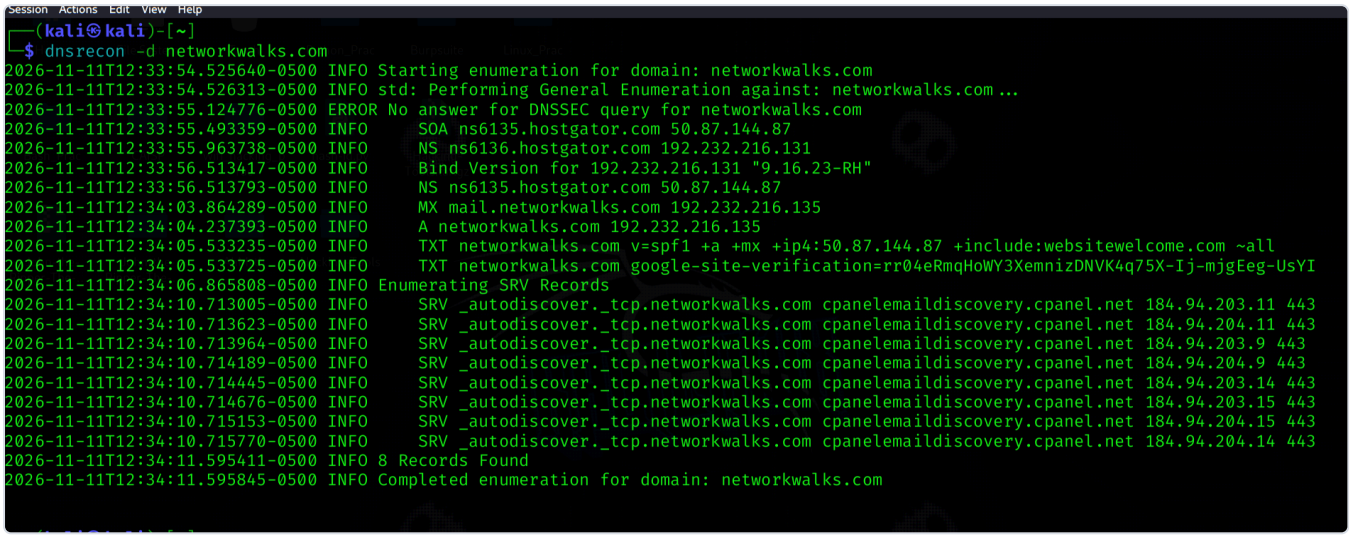


Figure 7 - dnsrecon enumeration of networkwalks.com

> **Impact:** The DNS footprint reveals mail infrastructure, the DNS software version and the email policy. A published BIND version helps attackers match known flaws, and an SPF record ending in `~all` is weaker against email spoofing than `-all`.

4.2 PM2 - Footprinting with GHDB (Google Dorks)

Method: I opened the Google Hacking Database on Exploit-DB, searched for relevant dorks (for example "cam"), ran each one in Google, opened the results and recorded those that matched. Where GHDB alone did not give ten results I used other public indexes, such as Insecam. This is **passive** recon: only publicly indexed pages were viewed.

> **Privacy note:** The last octet of raw IP addresses is masked (`xxx`) in this report because these are third-party devices. No credentials were used or needed.

Task 1 - Ten publicly exposed camera links

No.	Link	Relevant dork	User / Pass
1	http://109.233.191.xxx:8080	`intitle:"webcamXP" inurl:8080`	None
2	http://109.206.96.xxx:8080	`intitle:"webcamXP" inurl:8080`	None
3	http://109.233.191.xxx:8080/multi.html	`intitle:"webcamXP" inurl:8080`	None
4	http://72.199.200.xxx:8080/	`intitle:"webcamXP" inurl:8080`	None
5	http://75.149.26.xxx:1024/	`intitle:"webcamXP" inurl:8080`	None
6	https://www.lmc.edu/webcam.htm	`intitle:"Webcam" inurl:WebCam.htm`	None
7	http://99.114.240.xxx:8080/	`intitle:"Webcam" inurl:WebCam.htm`	None
8	https://www.towson.edu/campus/landmarks/webcam.html	`intitle:"Webcam" inurl:WebCam.htm`	None

9	http://www.insecam.org/en/view/986159/	`inurl:mobile.html intitle:webcamXP`	None
10	https://www.webcamxp.com/screenshots.aspx	`inurl:mobile.html intitle:webcamXP`	None

Task 2 - Ten listings with downloadable mathematics PDFs

No.	Link	Relevant dork
1	https://justmathbg.info/files/	`intitle: index of "parent directory" mathematics.pdf`
2	https://netlib.org/math/docpdf/	
3	https://mathflix.luc.edu/pdfs/Algebra/	
4	https://www.jsoftware.com/books/pdf/	
5	https://math-olymp.rudn.ru/doc/	
6	https://archive.org/details/cnx-org-col10615	`intitle: 'mathematics.pdf'`
7	https://batch.libretexts.org/print/Letter/Finished/math-48772/Full.pdf	
8	https://www.cambridge.org/core/books/abs/number-theory-and-polynomials/index-of-authors/0D7CE8B68FEC86CBBCA2B70768C7CF26	`intitle:"index of" "mathematics" filetype:pdf`
9	https://match.pmf.kg.ac.rs/electronic_versions/Match79/n2/match79n2_467-475.pdf	
10	https://webhomes.maths.ed.ac.uk/~v1ranick/papers/as4.pdf	

> **Impact:** Google already crawls almost everything a site exposes, so the right search can find exposed cameras, open folders and documents without touching the target at all. Several camera links here (university and vendor pages) are intentionally public, while the unauthenticated `webcamXP` streams are the kind owners often do not realise are open. The same dorks help defenders: search your own domain and lock down whatever it leaks.

4.3 PM4 - Footprinting with theHarvester

Target: `microsoft.com` (public OSINT only) · **Tool:** theHarvester 4.11.1 on Kali Linux · **Date:** 11 Nov 2026

Task 1 - Baidu source, limit 1000

Command: `theHarvester -d microsoft.com -l 1000 -b baidu`

Result: No IPs, no emails, no people and no hosts were returned from Baidu in this run. The module returned empty, which is a reminder that results depend on each source and can vary between runs.

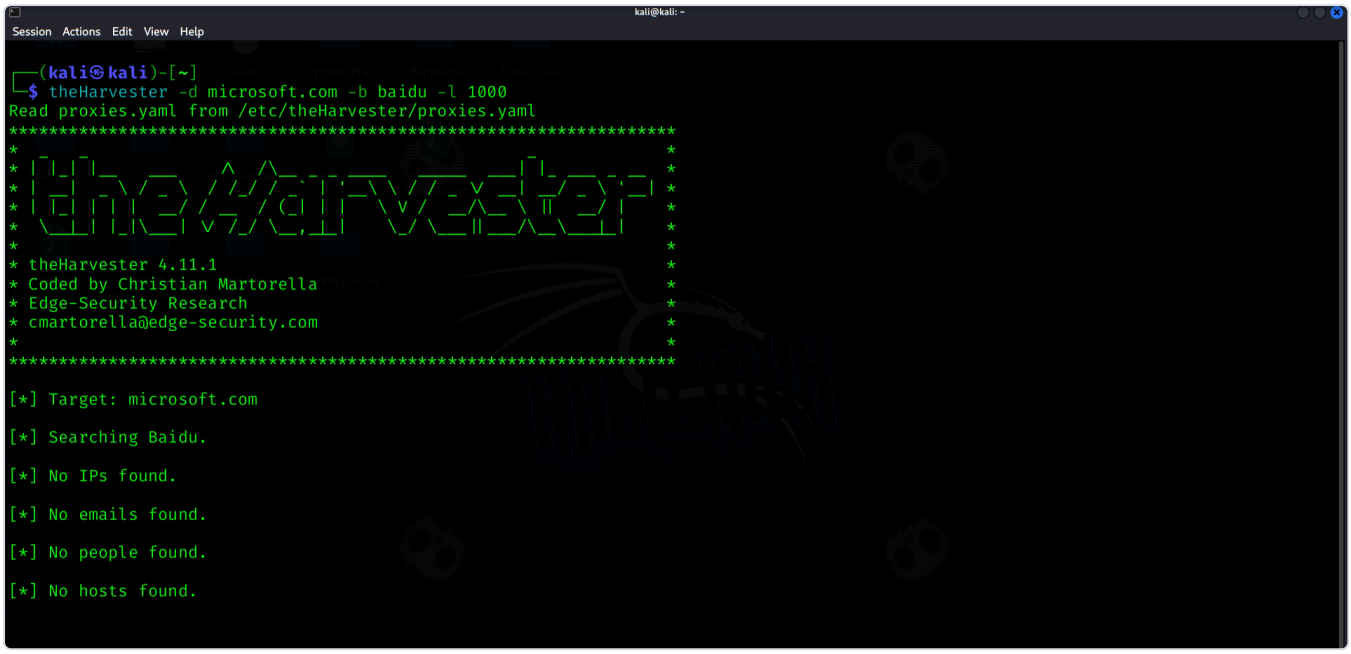


Figure 8 - theHarvester with the Baidu source: nothing found

Task 2 - all sources, limit 50

Command: `theHarvester -d microsoft.com -l 50 -b all`

Category	Result
IP addresses	**137** (e.g. 13.107.x.x, 40.x.x.x, 150.171.109.x ranges)
Emails	**3**: `dotnet-docker-bot@microsoft.com`, `opencode@microsoft.com`, `secure@microsoft.com` (role/service mailboxes, not individuals)
Hosts / sub-domains	**9,481** entries, including names that suggest non-production environments (`*.ppe.*`, `*-uat-*`, `*-int-*`, `test.*`)
LinkedIn links / people	0 / 0
Sources that failed	BeVigil, Bitbucket, BufferOver, BuiltWith, Brave, SecurityScorecard: *Missing API key*

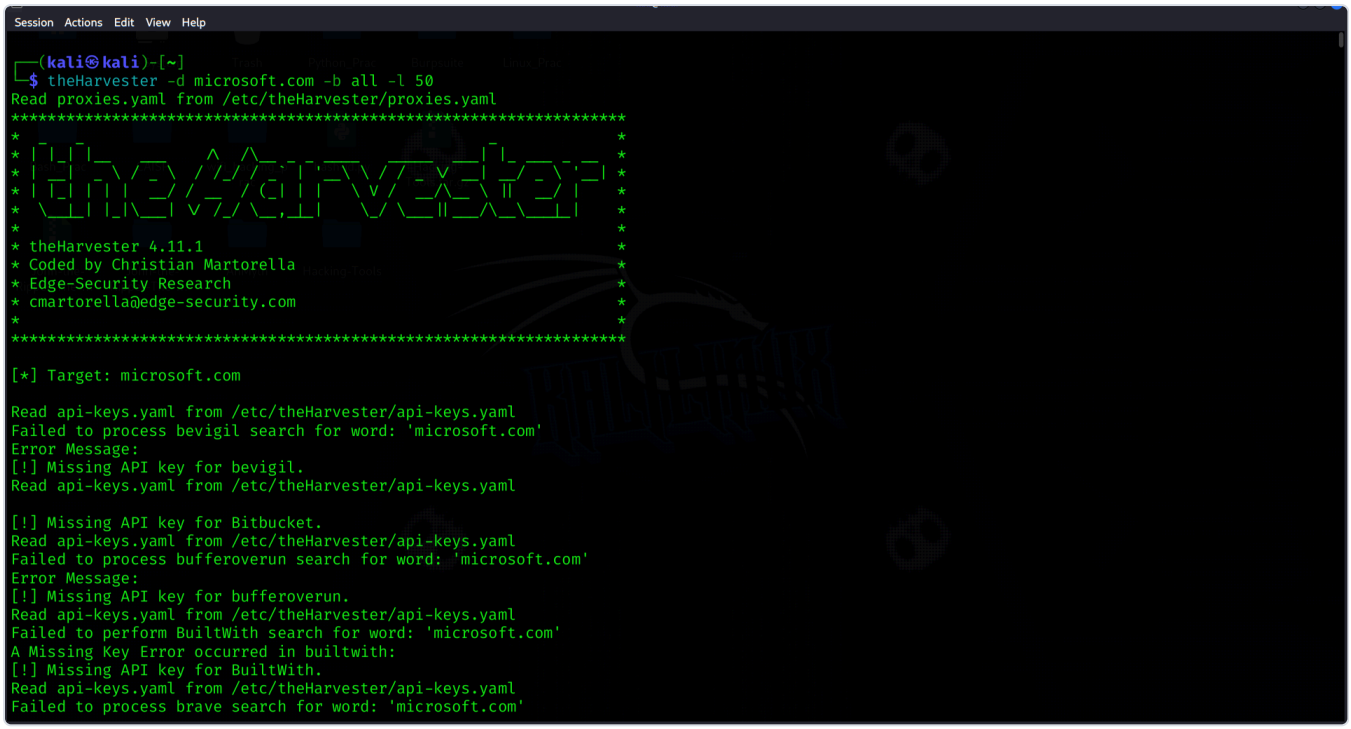


Figure 9 - all-sources run: start of output and missing-API-key messages

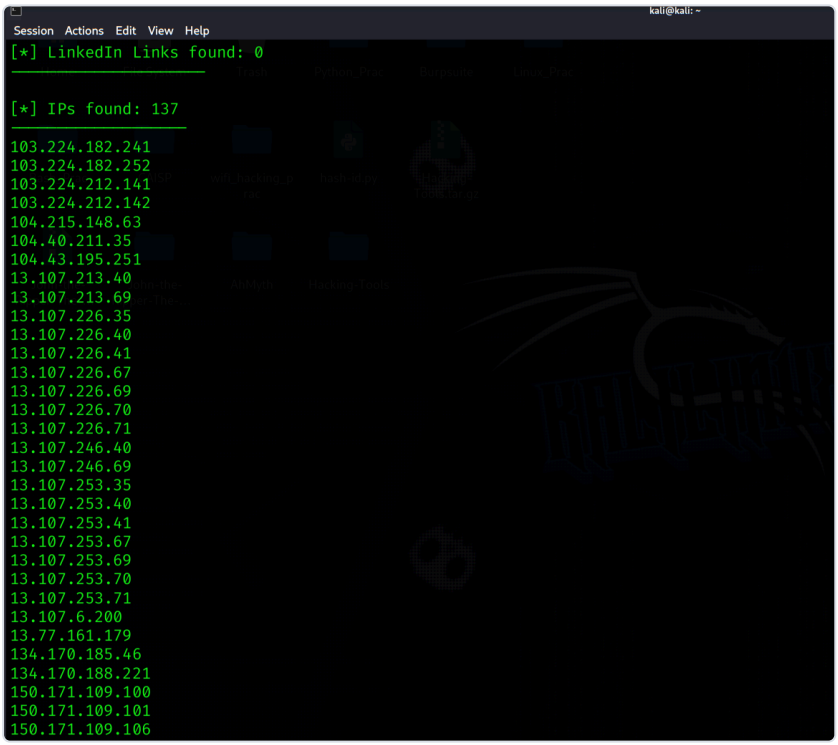


Figure 10 - LinkedIn links (0) and the start of the 137 IP addresses found

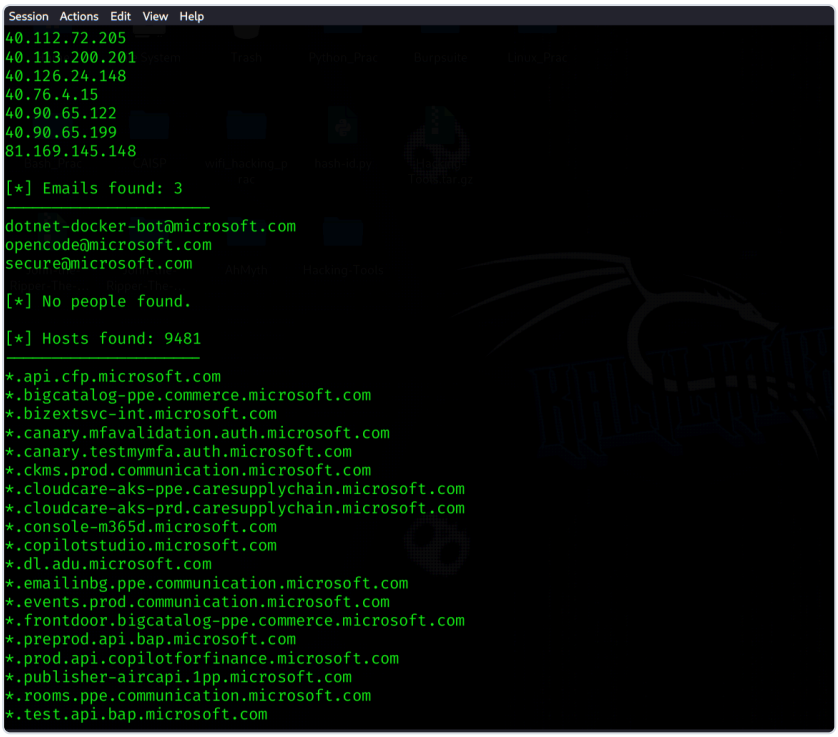


Figure 11 - three emails found and the start of the 9,481-host list

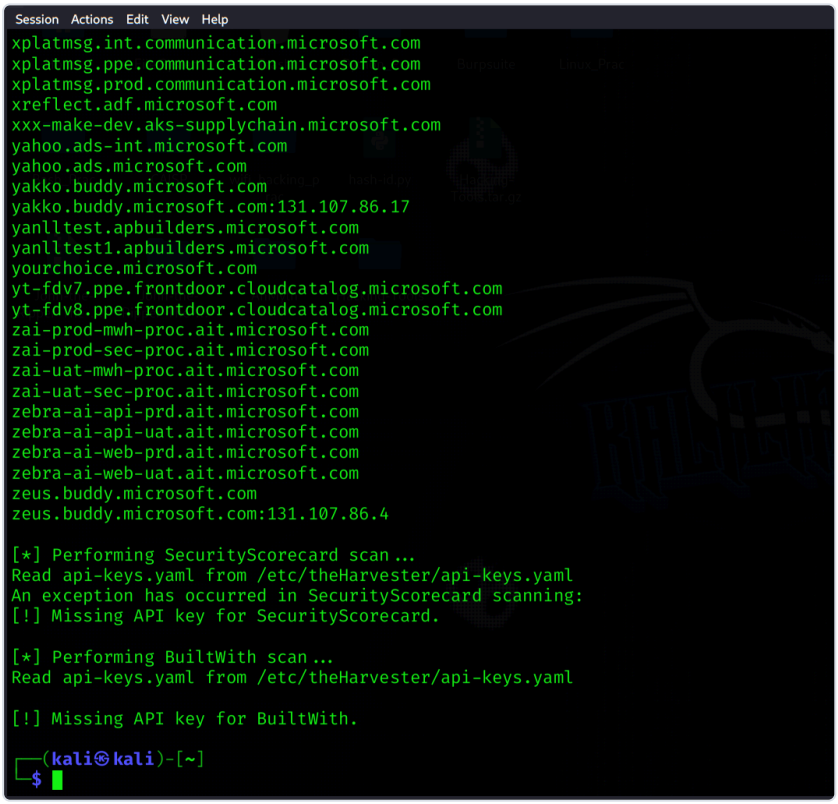


Figure 12 - end of the host list and final API-key warnings

> **Note:** The `-l 50` limit did not cap the totals shown, so it appears not every source module enforces it. Because several keyed sources failed, this run used only key-less sources; adding API keys would widen the results.
> **Impact:** Each harvested email is a potential phishing target, and each sub-domain is another possible entry point that may be forgotten or less protected, particularly test and pre-production hosts. theHarvester only reads public data, so the target never sees it.

4.4 PM5 - Network Scanning with Zenmap

Environment: Windows PC in my lab · **Tool:** Zenmap / Nmap 7.993 · **Date:** 12 Nov 2026

Task	What was asked	Result
1	Download and install Zenmap	Installed from nmap.org (`nmap-7.993-setup`) to `C:\Program Files (x86)\Nmap`
2	Local IP address and LAN subnet	IPv4 **10.0.0.10**, mask 255.255.255.0 → subnet **10.0.0.0/24**; gateway 10.0.0.1
3	Find live hosts (Ping Scan)	`nmap -sn 10.0.0.0/24` - 256 addresses scanned in 133.69 s
4	How many hosts are live?	**4 hosts** (including my own PC)
5	IP addresses of live hosts	10.0.0.1 · 10.0.0.2 · 10.0.0.3 · 10.0.0.10
6	MAC addresses	See table below
7	Topology saved as PDF	Exported from Zenmap (Topology → Save Graphic → PDF); preview in Figure 17

Host	MAC address	Vendor (as reported by Nmap)
10.0.0.1 (gateway)	`52:54:00:12:35:00`	QEMU virtual NIC
10.0.0.2	`08:00:27:8A:E5:07`	Oracle VirtualBox virtual NIC
10.0.0.3	`52:54:00:12:35:00`	QEMU virtual NIC
10.0.0.10 (my PC)	Not displayed by Nmap for the local host; run `ipconfig /all` to read it	-

Task 1 - Install Zenmap

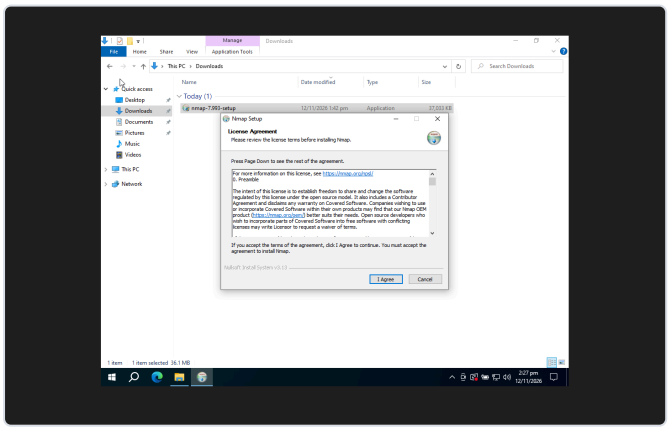


Figure 13 - Nmap setup: licence agreement

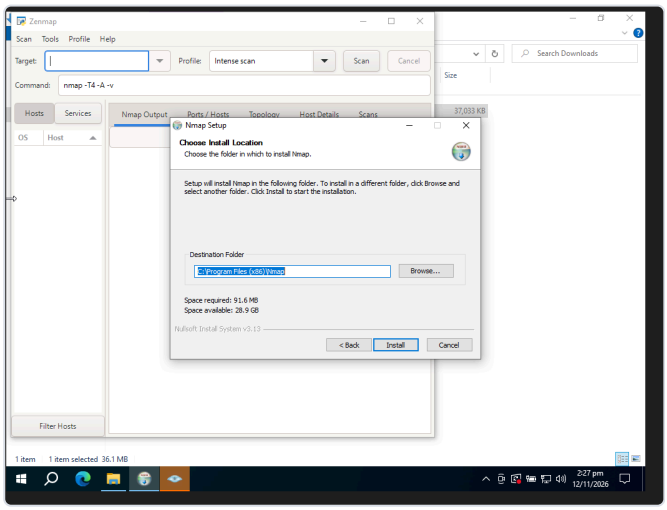


Figure 14 - Nmap setup: install location

Task 2 - Local IP address and subnet

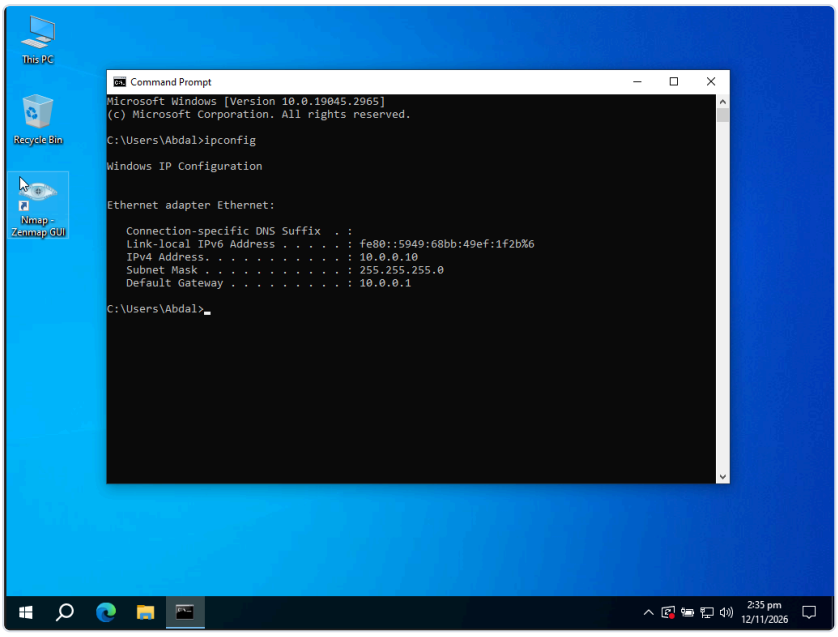


Figure 15 - `ipconfig`: 10.0.0.10 / 255.255.255.0, gateway 10.0.0.1

Tasks 3–6 - Ping scan, live hosts, IPs and MACs

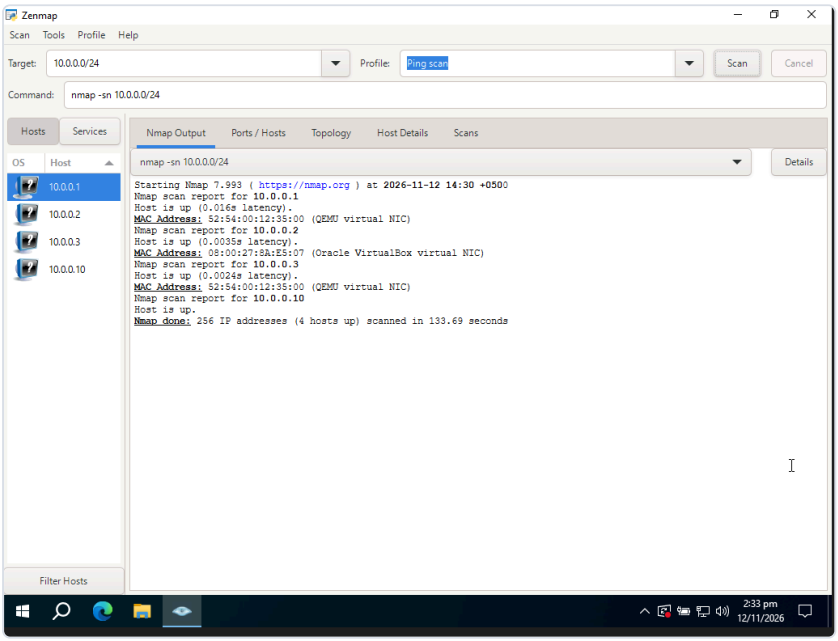


Figure 16 - Zenmap ping scan of 10.0.0.0/24: 4 hosts up

Task 7 - Network topology

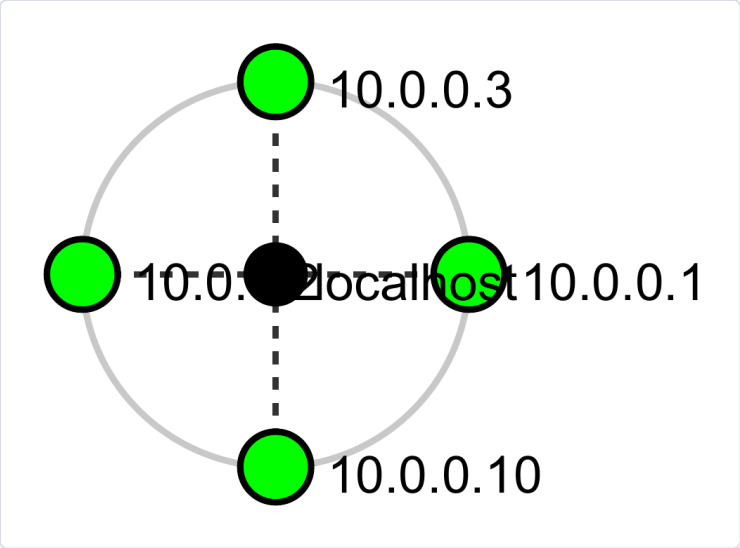


Figure 17 - Topology exported from Zenmap (full PDF: evidence/pm5-zenmap-topology.pdf)

> **Note:** 10.0.0.1 and 10.0.0.3 report the same MAC. That is typical of QEMU's user-mode networking, where each emulated NIC uses the default `52:54:00:12:35:00` address, so it points to a virtual lab rather than address spoofing. The exported topology graph does not show a legend.
> **Impact:** A ping scan quickly maps which devices are alive, and MAC vendor names show what they are (here, virtual machines). Defenders run the same scan to find unknown devices on their own network.

5. Risk Analysis / Impact

#	Finding	Evidence	Potential impact	Level
1	Unauthenticated camera streams discoverable via dorks	PM2: `webcamXP` pages on open ports, no login	Live feeds can be watched by anyone; privacy and physical-security exposure for the owners (some listed cameras are intentionally public)	Critical
2	Web technology and versions exposed	PM1 whatweb: WordPress 7.1.4, WP Download Manager 3.3.76, jQuery 3.7.1	Attackers can look up known issues for these exact versions	Medium
3	DNS details exposed	PM1 dnsrecon: BIND 9.16.23-RH banner, SPF `~all`, DNSSEC unsigned	Helps match DNS software flaws; softer email-spoofing protection	Medium
4	Large public sub-domain footprint	PM4: 9,481 host entries, 137 IPs, test/UAT/pre-prod names	Expands attack surface; non-production hosts are often less hardened	Medium
5	Server IP identifiable; web and mail share an IP	PM1 nslookup/dnsrecon: 192.232.216.135	Shows the network location of the service and its co-hosting	Low
6	HTTP headers reveal stack	PM1 curl: Apache, nginx/Endurance cache, Really Simple Security; cookie lacks `Secure`	Aids fingerprinting; small cookie hardening gap	Low
7	WAF technology identifiable	PM1 wafw00f: ModSecurity (SpiderLabs)	Reveals part of the security architecture (the WAF itself is a good control)	Low
8	Registration details public	PM1 whois: registrar, dates, name servers (registrant privacy on)	Supports planning and social-engineering pretexts	Low
9	Open directory listings indexed	PM2 Task 2: ten math-PDF listings	Directory indexing can leak files; the ones I found are public math resources	Low
10	Four live hosts on the lab LAN	PM5: 10.0.0.1, .2, .3, .10 (virtual NICs)	Any unknown device on a network would need to be verified	Low

Risk level key: Critical Medium Low

> The risks above are **observations** from footprinting and scanning, not confirmed vulnerabilities. No exploitation or vulnerability validation was performed. The presence of a software version, IP address or DNS record does not by itself mean a system is vulnerable; further authorised testing would be needed to confirm any actual weakness.

6. Recommendations

- **Limit what is public.** Remove version strings (WordPress generator tag, plugin versions) and unneeded response headers.
- **Patch consistently.** Keep the CMS, plugins and libraries current and follow their security advisories.
- **Harden DNS and email.** Hide the BIND version, consider enabling DNSSEC, and move SPF from `~all` to `-all` once every legitimate sender is listed.
- **Review the sub-domain inventory.** Retire stale test, UAT and pre-production hosts or restrict them to internal access.
- **Secure cookies.** Set `Secure` and `SameSite` on cookies and enforce HSTS.
- **Keep the WAF tuned and monitored.** ModSecurity already blocks naive attempts; keep its rules updated.
- **Dork your own assets.** Run GHDB-style searches against your own domains, and put authentication on every camera, admin page or file share.
- **Scan your own network regularly** and investigate any device you do not recognise; keep the network topology documented.
- **Test only with authorisation.** Reconnaissance and scanning should be done only on systems where written permission exists.

7. Notes and Limitations

- Results reflect what each tool and source returned on 11–12 November 2026 and may change; the task PDFs show example values that differ from mine (for example, WordPress 7.1.4 here versus 7.0.4 in the example).
- For the curl task I ran `curl -i` rather than `curl -I`; both show the headers, and the redirect response has no body.
- The local PC's own MAC address is not displayed by the Nmap scan and was not captured separately.
- theHarvester's Baidu run returned nothing, and keyed sources were unavailable (no API keys configured).
- The GHDB links were gathered as public search results; I did not interact with any device, so I make no claim about their present state or ownership.

8. Conclusion

In Week 2 I worked through the first two phases of a penetration test. Six Kali tools built a profile of networkwalks.com: its registrar and hosting, WordPress stack, IP address, headers, WAF and DNS records. Google dorks showed how much a search engine alone can reveal, from open directories to unauthenticated cameras. theHarvester showed how many IPs, emails and sub-domains an organisation exposes through public sources, and Zenmap showed how quickly a ping scan maps live hosts on a network.

The main lesson is that information gathering is powerful, quiet and mostly legal when it uses public data, and that defenders can run the same techniques on themselves to shrink their attack surface. I also learned to document what was run, what came back, what it means and how to reduce the risk, and to stay inside an authorised scope at all times. All of this was done as part of the Week 2 lab assignments.

9. Evidence Index

File	Shows
`pm1-01-whois-registry.png`	whois - registry record
`pm1-02-whois-registrar.png`	whois - registrar record, privacy-protected contacts

pm1-03-whatweb.png	whatweb fingerprint
pm1-04-nslookup.png	nslookup - IP resolution
pm1-05-curl-headers.png	curl - HTTP response headers
pm1-06-wafw00f.png	wafw00f - ModSecurity detected
pm1-07-dnsrecon.png	dnsrecon - DNS records
pm4-01 … pm4-05 *.png	theHarvester - Baidu run (1) and all-sources run (4 screenshots)
pm5-01 … pm5-05 *.png	Zenmap install (2), ipconfig, ping scan, topology
evidence/pm1-raw-tool-output.txt	Raw text output of the six PM1 tools
evidence/pm5-zenmap-topology.pdf	Topology PDF exported from Zenmap

---

Author: Muhammad Abdal Khan (B084) - Cybersecurity & Ethical Hacking intern
Program: Cybersecurity program at Networkwalks | **Week:** 02 | **Repository:** GitHub

End of report